AIGP Module 6: The EU AI Act

Comprehensive Study Notes

---

1. INTRODUCTION TO THE EU AI ACT

1.1 Overview

Official Name: Regulation (EU) 2024/1689 on Artificial Intelligence (AI Act)

Adoption: Approved by European Parliament in March 2024, entered into force in August 2024

Significance:

- World's first comprehensive AI regulation
- Horizontal regulation (applies across all sectors)
- Risk-based approach
- Extraterritorial reach (affects organizations worldwide)
- Sets global precedent for AI regulation

Purpose:

- Ensure AI systems in EU market are safe
- Protect fundamental rights, democracy, rule of law
- Harmonize rules across EU member states
- Support innovation while managing risks
- Create legal certainty for businesses and users

Scope: Applies to:

- Providers placing AI systems on EU market (regardless of location)
- Deployers of AI systems in EU
- Providers and deployers in EU
- Importers and distributors making AI available in EU
- AI outputs used in EU

1.2 Key Principles

Risk-Based Approach:

- AI systems classified by risk level
- Stricter requirements for higher risk

Narahari

- Proportionate regulation

Human-Centric:

- Fundamental rights protection
- Human oversight requirements
- Democratic values

Harmonization:

- Uniform rules across EU
- Single market for AI
- Mutual recognition

Innovation Support:

- Regulatory sandboxes
- Flexibility for SMEs and startups
- Support for AI development

Enforcement:

- Significant penalties for violations
- Market surveillance authorities
- European AI Office oversight

1.3 Extraterritorial Reach

Applies To:

- Providers placing AI in EU market (even if located outside EU)
- AI outputs used in EU
- Similar to GDPR's extraterritorial scope

Example: U.S. company providing AI system used by EU customers must comply

Why It Matters Globally:

- Many organizations will need to comply regardless of location
- May set global standard (similar to GDPR effect)
- "Brussels Effect"—EU regulations influencing global practices

---

2. KEY DEFINITIONS AND ROLES

2.1 AI System Definition

Narahari

Article 3(1): "AI system" means a machine-based system that is designed to operate with varying levels of autonomy and that may exhibit adaptiveness after deployment, and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments.

Key Elements:

- Machine-based system
- Varying levels of autonomy
- May adapt after deployment
- Infers from inputs how to generate outputs
- Outputs: predictions, content, recommendations, decisions
- Can influence environments

Broad Definition: Covers traditional ML, generative AI, rule-based systems with learning, etc.

2.2 Key Roles and Responsibilities

Provider:

Definition: Person/entity that develops AI system or has it developed, and places it on EU market or puts it into service under their own name or trademark

Key Responsibilities:

- Design and develop compliant AI system
- Conduct risk management (Article 9)
- Data and data governance (Article 10)
- Technical documentation (Article 11)
- Logging capabilities (Article 12)
- Transparency to deployers (Article 13)
- Human oversight design (Article 14)
- Accuracy, robustness, cybersecurity (Article 15)
- Quality management system (Article 17)
- Conformity assessment (Article 43)
- EU declaration of conformity
- CE marking (for high-risk systems)
- Registration in EU database

Narahari

- Post-market monitoring (Article 72)
- Serious incident reporting (Article 73)

Examples:

- AI software company developing chatbot
- Company creating facial recognition system
- Organization building credit scoring model for market

Deployer:

Definition: Person/entity using AI system under their authority, except for personal non-professional activity

Key Responsibilities:

- Use AI according to instructions
- Human oversight (Article 26)
- Monitor operation and report serious incidents
- Conduct Fundamental Rights Impact Assessment (FRIA) for high-risk AI in certain contexts (Article 27)
- Inform provider of serious incidents
- Suspend use if non-compliant
- Data protection compliance (controller/processor obligations)
- Transparency obligations (inform affected persons)

Examples:

- Hospital using AI diagnostic system
- Bank deploying credit scoring AI
- Employer using AI recruitment tool
- Public authority using facial recognition

Note: Deployer can also be provider if they modify or use under own name

---

Importer:

Definition: Person/entity established in EU placing on market AI system bearing name/trademark of non-EU person

Key Responsibilities:

- Verify provider has conducted conformity assessment

Narahari

- Verify technical documentation exists
- Verify CE marking and EU declaration of conformity
- Ensure provider registered in EU database
- Provide market surveillance authorities with information
- Own name/address on AI system or documentation
- Ensure compliance during storage/transport
- Report non-compliance to provider and authorities

Examples:

- EU distributor importing U.S.-developed AI software
- EU company bringing non-EU AI hardware to market

Distributor:

Definition: Person/entity in supply chain, other than provider or importer, making AI system available on EU market

Key Responsibilities:

- Verify CE marking present
- Verify required documentation exists
- Verify provider and importer complied with obligations
- Ensure compliance during storage/transport
- Report non-compliance to provider/importer and authorities
- Cooperative with authorities

Examples:

- Retailer selling AI-enabled devices
- Reseller of AI software
- VAR (Value-Added Reseller) of AI systems

Authorized Representative:

Definition: Person/entity in EU mandated by non-EU provider to act on their behalf for EU AI Act compliance

Responsibilities:

- Acts on behalf of provider for compliance tasks
- Contact point for authorities

Narahari

- Maintains documentation
- Responds to authority requests

Notified Body:

Definition: Conformity assessment body designated by member state to conduct third-party conformity assessments for certain high-risk AI

Role:

- Independent assessment of compliance
- Issues certificates for conformity
- Ongoing monitoring of certified systems

---

3. RISK-BASED CLASSIFICATION

3.1 Four Risk Categories

The EU AI Act classifies AI systems into four risk levels with corresponding obligations:

3.2 PROHIBITED AI PRACTICES (Unacceptable Risk)

Article 5: AI systems posing unacceptable risk to safety or fundamental rights are **banned**

Prohibited Practices:

---

1. Manipulative and Exploitative Systems (Article 5(1)(a)):

Subliminal Techniques: AI using subliminal techniques beyond person's consciousness to materially distort behavior in harmful way

Exploitation of Vulnerabilities: AI exploiting vulnerabilities of specific groups (age, disability, social/economic situation) to materially distort behavior in harmful way

Examples:

- Voice-activated toy encouraging dangerous behavior in children
- AI targeting elderly with scams by exploiting confusion
- Dark patterns manipulating vulnerable users

---

2. Social Scoring (Article 5(1)©):

Definition: AI evaluating or classifying persons based on social behavior or personal characteristics, leading to detrimental treatment

Narahari

Characteristics:

- Evaluation over time
- Based on social behavior, personality
- Leads to unjustified or disproportionate treatment
- Treatment unrelated to context or disproportionate to behavior

Examples:

- Government social credit system (like China's)
- Comprehensive social scoring by public or private entity
- Generalizing behavior across contexts

Not Prohibited:

- Credit scoring (limited to financial context)
- Specific assessments for specific purposes (if proportionate)

---

3. Predictive Policing Based on Profiling (Article 5(1)(d)):

Definition: AI assessing risk of individuals committing criminal offenses based solely on profiling or personality traits

Why Prohibited:

- Can be discriminatory
- Presumption of innocence concerns
- Based on characteristics, not actual behavior
- Risk of targeting minorities

Key: "Solely" based on profiling—risk assessment using actual evidence not prohibited

Example Prohibited: AI flagging individuals as crime risks based on demographics, appearance, or neighborhood

Example Allowed: AI analyzing actual criminal intelligence, suspect behavior patterns, specific evidence

---

4. Facial Recognition Databases (Article 5(1)(e)):

Untargeted Scraping: Creating or expanding facial recognition databases through untargeted scraping of facial images from internet or CCTV

Why Prohibited:

- Privacy violations

Narahari

- Lack of consent
- Mass surveillance risk
- Disproportionate

Example: Scraping social media for facial images to build recognition database

---

5. Emotion Recognition in Specific Contexts (Article 5(1)(f)):

Workplace and Education: Inferring emotions in workplace or educational institutions

Exceptions:

- Medical or safety reasons
- Research purposes

Why Restricted:

- Questionable accuracy of emotion recognition
- Privacy concerns
- Power imbalance in workplace/school
- Potential for manipulation or discrimination

Example Prohibited: Employer using AI to monitor employee emotions for performance management

Example Allowed: Research study on emotion recognition with consent

---

6. Biometric Categorization Using Sensitive Characteristics (Article 5(1)(g)):

Definition: AI inferring sensitive attributes (race, political opinions, trade union membership, religious/philosophical beliefs, sex life, sexual orientation) from biometric data

Exception: Labeling/filtering lawfully acquired biometric datasets (e.g., law enforcement)

Why Prohibited:

- Infers protected characteristics without consent
- High discrimination risk
- Violates human dignity

Example: AI categorizing people by race from facial images for commercial purposes

---

7. Real-Time Remote Biometric Identification (RBI) in Publicly Accessible Spaces for Law Enforcement (Article 5(1)(h)):

Narahari

General Prohibition: Real-time remote biometric identification (especially facial recognition) by law enforcement in publicly accessible spaces

Exceptions (Strictly Limited):

Allowed only for:

1. **Targeted search for victims** (missing children, abduction, trafficking victims)
2. **Prevention of specific, substantial, imminent threat** to life, physical safety, or terrorist attack
3. **Detection, localization, identification, prosecution of serious crimes** (punishable by at least 3 years imprisonment)

Conditions for Exception:

- Prior judicial or independent authority authorization (except emergency—then within 24 hours)
- Proportionate and necessary
- Limited in time and geographic scope
- Specific purpose
- Sufficient safeguards

Not Prohibited: "Post" or non-real-time use (reviewing recorded footage)

Example Prohibited: Continuous facial recognition surveillance of public streets for general law enforcement

Example Allowed: Real-time facial recognition with judicial authorization to locate kidnapped child

---

Penalties for Prohibited AI: Up to **€35 million or 7% of global annual turnover** (whichever higher)

3.3 HIGH-RISK AI SYSTEMS

Definition: AI systems posing significant risks to health, safety, or fundamental rights

Consequences: Subject to extensive regulatory requirements before and during market placement

---

3.3.1 Categories of High-Risk AI (Annex III)

Two Main Categories:

1. AI systems intended as safety components of products covered by specified EU legislation (e.g., machinery, medical devices, toys)

Narahari

2. AI systems in specific areas listed in Annex III:

Category 1: Biometrics:

- Remote biometric identification (except real-time for law enforcement—prohibited with exceptions)
- Biometric categorization (sensitive attributes)
- Emotion recognition

Category 2: Critical Infrastructure:

- AI managing or operating critical infrastructure (water, gas, electricity, transport)
- Risk to public safety or essential services

Category 3: Education and Vocational Training:

- Determining access or admission to education
- Assessing students
- Monitoring/detecting prohibited behavior (e.g., exam cheating)
- Evaluating learning outcomes

Examples:

- AI deciding university admissions
- Automated proctoring systems
- Student assessment tools

Category 4: Employment:

- Recruitment and hiring (sorting, filtering applications)
- Making decisions on promotion, termination
- Task allocation
- Monitoring and evaluating performance

Examples:

- Resume screening AI
- Hiring recommendation systems
- Performance monitoring tools

Narahari

Relevance: NYC Local Law 144 (U.S.) is similar—bias audits for employment AI

Category 5: Access to Essential Services:

- Evaluating eligibility for essential public assistance and services (healthcare, social services)
- Assessing creditworthiness (except fraud detection)
- Evaluating credit score
- Risk assessment for insurance pricing, terms

Examples:

- AI determining welfare benefits eligibility
- Credit scoring models
- Insurance underwriting AI

Category 6: Law Enforcement:

- Risk assessment for criminal offense likelihood or recurrence
- Polygraph/lie detection tools
- Evaluating reliability of evidence
- Assessing flight risk or recidivism
- Profiling during criminal investigation
- Crime analytics (prediction of occurrence, patterns)

Examples:

- Recidivism prediction tools
- Predictive policing (location-based crime forecasting)
- Evidence evaluation AI

Category 7: Migration, Asylum, Border Control:

- Polygraph/lie detection for asylum/visa
- Assessing security/irregular migration/health risks
- Examining asylum/visa applications
- Detecting false documents

Examples:

Narahari

- Automated visa decision systems
- Border control risk assessment

Category 8: Justice and Democratic Processes:

- Assisting judicial authorities in researching, interpreting law, applying to facts
- Influencing outcomes of elections or referenda
- Influencing voting behavior

Examples:

- AI assisting judges with legal research/case analysis
- Systems targeting political advertising
- AI influencing voter opinions

3.3.2 High-Risk AI: Provider Obligations

Providers of high-risk AI must comply with **Articles 9-15** and broader governance requirements:

Article 9: Risk Management System:

Requirement: Establish, implement, document, and maintain risk management system throughout AI lifecycle

Components:

- Risk identification and analysis (known and foreseeable risks)
- Risk estimation and evaluation (against risk management measures)
- Risk mitigation (eliminate or reduce to acceptable level)
- Testing and validation
- Residual risk evaluation and information to deployer
- Post-market monitoring and feedback loop

Continuous Process: Iterative throughout lifecycle

Documentation: Must be documented and updated

Article 10: Data and Data Governance:

Requirement: Training, validation, testing datasets must meet quality criteria

Quality Criteria:

Narahari

- **Relevant**: Appropriate for intended purpose
- **Sufficiently representative**: Cover situations, contexts, inputs expected
- **Error-free**: To extent necessary
- **Complete**: Include all relevant data
- **Appropriate statistical properties**: Including for minority groups

Bias Mitigation:

- Examine training data for biases
- Detect and address biases
- Use appropriate data governance measures

Data Processing:

- Relevant design choices for data processing
- Formulation of assumptions
- Prior assessment of availability, quality, suitability
- Data gaps addressed (not filled with unrepresentative data)

Special Category Data: Extra care if using sensitive data (GDPR Article 9)

Article 11: Technical Documentation:

Requirement: Draw up and maintain technical documentation demonstrating compliance

Content (Annex IV):

- General description of AI system
- Detailed description (architecture, components, algorithms)
- Development process
- Datasets used (training, validation, testing)
- Monitoring, functioning, control
- Risk management system
- Changes and versions
- Instructions for use
- Validation and testing procedures
- Cybersecurity measures

Purpose: Enable authorities to assess compliance

Retention: Keep up-to-date; retain 10 years after system placed on market

Narahari

Article 12: Record-Keeping (Logging):

Requirement: High-risk AI designed to automatically log events (logs) during operation

Purpose:

- Traceability
- Enable monitoring
- Facilitate post-market monitoring
- Investigation of incidents

What to Log:

- Operating period
- Reference database
- Input data
- Persons involved in verification
- Other relevant events

Retention: Appropriate to intended purpose; accessible to provider and deployer

Balance: Logging vs. data protection and privacy

Article 13: Transparency and Information to Deployers:

Requirement: Provide deployers with clear, comprehensive information and instructions

Information to Include:

- Identity and contact details of provider
- Characteristics, capabilities, limitations of AI
- Performance metrics (accuracy, robustness, cybersecurity)
- Changes and updates
- Human oversight measures
- Expected lifetime and maintenance
- Instructions for use (installation, operation, troubleshooting)

Purpose: Enable deployer to comply with their obligations and use system properly

Format: Clear, accessible instructions for use

Article 14: Human Oversight:

Narahari

Requirement: High-risk AI designed to enable effective human oversight

Goal: Prevent or minimize risks to health, safety, fundamental rights

Oversight Measures:

- Assigned to natural persons with competence, training, authority
- Full understanding of AI capabilities and limitations
- Ability to monitor operation
- Ability to interpret outputs
- Ability to intervene, interrupt, stop (stop button)
- Human decision-making supported, not replaced

Human Oversight Capabilities:

- Understand automated decisions
- Identify anomalies, dysfunctions, unexpected performance
- Decide not to use or override output
- Intervene or interrupt through stop button

Design Requirements: AI system must enable above (technical feasibility)

Article 15: Accuracy, Robustness, Cybersecurity:

Accuracy:

- Resilient level of accuracy stated in instructions
- Consistent throughout lifecycle

Robustness:

- Resilient to errors, faults, inconsistencies
- Handle errors appropriately
- Resilient to attempts by unauthorized third parties to manipulate

Cybersecurity:

- Resilient against cyberattacks
- Security measures appropriate to risks
- Protection against data poisoning, model evasion, etc.

Testing: Must be achieved through development, validation, testing

---

Article 17: Quality Management System (QMS):

Narahari

Requirement: Providers establish and maintain QMS ensuring compliance

Components:

- Strategy for regulatory compliance
- Design, development, quality control techniques, procedures
- Data management (collection, analysis, labeling, storage, aggregation, retention, etc.)
- Technical documentation maintenance
- Record-keeping (logging) system
- Post-market monitoring system
- Procedures for reporting serious incidents
- Communication with authorities, notified bodies, competent authorities
- System validation and periodic review

Standards: May reference harmonized standards (e.g., ISO 42001)

Documentation: QMS must be documented systematically

Article 43: Conformity Assessment:

Requirement: Before placing high-risk AI on market, undergo conformity assessment

Purpose: Demonstrate compliance with requirements

Types:

1. Internal Conformity Assessment (Self-Assessment - Most Common):

- Provider conducts own assessment
- Based on internal checks
- If compliant, draws up EU declaration of conformity
- Affixes CE marking

2. Third-Party Conformity Assessment (by Notified Body):

- Required for specific high-risk categories:
    - Biometric identification and categorization (Annex III, point 1)
    - Certain critical infrastructure (if harmonized standards not met)
- Independent assessment by notified body
- More rigorous
- Notified body issues certificate

Process:

Narahari

1. Verify technical documentation
2. Verify QMS established
3. Check compliance with requirements (Articles 9-15)
4. Testing and validation evidence
5. If compliant: EU declaration of conformity + CE marking
6. Registration in EU database

Substantial Modification: Requires new conformity assessment

CE Marking:

Requirement: High-risk AI that complies must bear CE marking

Purpose: Indicates conformity with EU AI Act and other applicable regulations

Visibility: Affixed to AI system or packaging; if not possible, in accompanying documentation

Significance: Allows free movement in EU market

EU Database Registration:

Requirement (Article 71): Providers must register high-risk AI in EU database **before** placing on market

Information:

- Provider identity and contact
- AI system description and intended purpose
- Reference to instructions for use
- EU declaration of conformity
- URL for additional information

Public Access: Database is publicly accessible (transparency)

Deployer Obligations: Some deployers must also register use (public authorities, certain services of general interest)

3.3.3 High-Risk AI: Deployer Obligations

Article 26: Deployer Obligations:

Use According to Instructions:

- Follow provider's instructions for use

Narahari

- Use only for intended purpose

Human Oversight (Article 26(4)):

- Ensure human oversight measures as designed
- Assign oversight to competent, trained persons
- Persons can interpret outputs and intervene

Input Data Monitoring:

- Ensure input data relevant and sufficiently representative
- Monitor for risks of bias

Monitoring and Logging (Article 26(5)):

- Monitor operation based on instructions
- Use logs provided by system
- Report serious incidents to provider and authorities

Suspend Use if Non-Compliant (Article 26(7)):

- If reason to believe AI non-compliant, suspend use
- Inform provider and authorities

Article 27: Fundamental Rights Impact Assessment (FRIA):

Requirement: Deployers of high-risk AI in specific contexts must conduct FRIA **before** putting into use

When Required:

- Deployers who are public authorities or EU institutions, OR
- Deployers providing services of general interest (education, healthcare, housing, employment, etc.)

Exemption: Not required if impact already assessed by provider (rare)

FRIA Content:

- Description of deployer's processes involving high-risk AI
- Categories of persons and groups likely affected
- Risk of harm to fundamental rights
- Description of safeguards and measures to mitigate risks
- Consultations conducted (data subjects, experts, etc.)

Process:

1. Describe AI use and context

Narahari

2. Identify affected populations
3. Assess fundamental rights impacts (privacy, non-discrimination, due process, etc.)
4. Evaluate severity and likelihood
5. Consult stakeholders (including affected communities)
6. Document safeguards and mitigation
7. Approve and document

Public Availability: Summary made publicly available (transparency)

Update: When significant change in use of AI

Other Deployer Obligations:

- Transparency: Inform persons that they're subject to high-risk AI (Article 26(8))
- Data protection: Comply with GDPR (controller/processor obligations)
- Cooperation with authorities
- Maintain logs as provided by system

3.3.4 Importer and Distributor Obligations for High-Risk AI

Importers:

- Verify provider conducted conformity assessment
- Verify CE marking and EU declaration of conformity
- Verify provider registered in EU database
- Ensure instructions in language understood by deployers
- Provide authorities with information upon request

Distributors:

- Verify CE marking present
- Verify instructions and required documentation available
- Report non-compliance to provider/importer and authorities
- Ensure compliance during storage/transport

3.4 LIMITED RISK AI (Transparency Obligations)

Definition: AI systems with specific transparency risks but not classified as high-risk

Article 50: Transparency Obligations:

Narahari

---

1. AI Interacting with Humans (Article 50(1)):

Requirement: Providers must design AI to inform natural persons that they're interacting with AI

Exceptions:

- Obvious from context
- Authorized by law for law enforcement (detection, investigation, prosecution)

Examples:

- Chatbots: "You're chatting with an AI assistant"
- Virtual assistants: Clear indication it's AI
- Customer service bots

Purpose: Prevent deception; enable informed decisions

---

2. Emotion Recognition and Biometric Categorization (Article 50(2)):

Requirement: Deployers must inform persons subjected to:

- Emotion recognition systems
- Biometric categorization systems

Exceptions: Authorized by law for law enforcement

Example: Airport using emotion recognition must inform travelers

---

3. Deep Fakes and AI-Generated Content (Article 50(3-4)):

Requirement: Deployers of AI generating or manipulating content must disclose that content is AI-generated

Applies To:

- AI-generated images, audio, video (deepfakes)
- Manipulated content (appearing authentic but AI-altered)

Disclosure Requirements:

- Machine-readable format (technical metadata)
- Human-detectable way (visible watermark or label)

Example: AI-generated political ad must be labeled "AI-generated content"

Exceptions:

- Authorized by law for law enforcement, freedom of expression/arts (but with appropriate safeguards)

Narahari

- AI for editing, creative assistance (not creating entirely new content)

---

4. Text Content (Article 50(4)):

Requirement: Text generated or manipulated by AI and published to inform public must disclose AI generation

Example: AI-generated news articles, blog posts must be labeled

Exception: Human review/editorial control + person assumes responsibility (can avoid labeling)

Penalties for Transparency Violations: Up to **€15 million or 3% of global annual turnover** (whichever higher)

3.5 MINIMAL/NO RISK AI

Definition: AI systems not prohibited, high-risk, or subject to transparency requirements

Obligations: No specific EU AI Act obligations (but other laws still apply—GDPR, consumer protection, etc.)

Examples:

- Spam filters
- AI-enabled video games
- Inventory management AI
- Basic recommendation systems (for non-essential contexts)

Voluntary: Organizations can adopt codes of conduct and best practices voluntarily

---

4. GENERAL-PURPOSE AI (GPAI) MODELS

4.1 Definition

Article 3(63): "General-purpose AI model" means an AI model, including when trained with large amounts of data using self-supervision at scale, that displays significant generality and is capable of competently performing a wide range of distinct tasks regardless of the way the model is placed on the market and that can be integrated into a variety of downstream systems or applications, except AI models that are used for research, development, or prototyping activities before they are placed on the market.

Key Characteristics:

- Trained on large, diverse data
- Capable of wide range of tasks
- Generality (not task-specific)

Narahari

- Can be integrated into various applications

Examples:

- Large language models (GPT series, Claude, Llama)
- Multimodal foundation models (GPT-4 with vision, Gemini)
- Base models used for fine-tuning

4.2 Two Tiers of GPAI

1. Standard GPAI Models: General-purpose AI without systemic risk

2. GPAI Models with Systemic Risk: High-impact models posing systemic risks

---

4.3 Standard GPAI Model Obligations (Article 53)

Applies To: Providers of GPAI models (not reaching systemic risk threshold)

---

1. Technical Documentation (Article 53(1)(a)):

Requirement: Draw up and keep technical documentation including:

- Training process description (data sources, curation)
- Model architecture and parameters
- Testing and evaluation results
- Energy consumption for training

Purpose: Enable downstream providers to comply with obligations

Audience: Provided to downstream providers and authorities upon request

---

2. Information and Documentation to Downstream Providers (Article 53(1)(b)):

Requirement: Provide sufficient information and documentation to enable downstream providers (who integrate GPAI into their systems) to comply with obligations

Content:

- Model capabilities and limitations
- Instructions for use and integration
- Access modalities (API, open-source, etc.)
- Risk information
- Mitigation measures

Narahari

Purpose: Enable downstream providers to conduct risk assessments, develop safe systems

---

3. Copyright Compliance Policy (Article 53(1)©):

Requirement: Put in place policy to comply with EU copyright law, particularly regarding text and data mining (TDM)

Context: Training AI on copyrighted content raises legal questions

Content:

- Policy on respecting copyright
- Opt-out mechanisms for rights holders (who reserve TDM rights under Article 4(3) of Directive 2019/790)
- Transparency about data sources

Purpose: Balance AI innovation with copyright protection

---

4. Publicly Available Summary of Training Data (Article 53(1)(d)):

Requirement: Make publicly available a sufficiently detailed summary of the content used for training

Purpose: Transparency about what data was used (important for copyright, bias, quality assessment)

Content: Summary (not complete list)—description of data sources, types, curation methods

Challenge: Balance transparency with trade secrets

****4.4 GPAI Models with Systemic Risk (Article 51)**

Definition (Article 51): GPAI model meeting criteria in Article 51:

Threshold: Has high-impact capabilities evaluated on basis of appropriate technical tools and methodologies, including indicators and benchmarks

Presumption: Model trained with >10^25 FLOPs (floating point operations) presumed to have systemic risk (rebuttable)

AI Office Designation: European AI Office can designate models as systemic risk based on assessment

---

Why "Systemic Risk"?:

- Capabilities could be misused for serious harm at scale
- Wide dissemination and reach

Narahari

- Significant impact on internal market, society, public security
- Example risks: Bioterrorism, large-scale cyberattacks, creation of weapons

---

4.5 GPAI with Systemic Risk: Additional Obligations (Article 55)

All Standard GPAI Obligations (Article 53) PLUS:

---

1. Model Evaluation (Article 55(1)(a)):

Requirement: Perform model evaluation in accordance with standardized protocols and tools

Purpose: Identify and assess systemic risks

Content:

- Evaluate dangerous capabilities
- Test for dual-use potential
- Benchmark against recognized standards
- Document evaluation methodology and results

---

2. Adversarial Testing (Red Teaming) (Article 55(1)(a)):

Requirement: Perform adversarial testing of model to identify systemic risks

Process:

- Red teaming by experts
- Attempt to find vulnerabilities, misuse vectors
- Document findings and mitigations

---

3. Assess and Mitigate Systemic Risks (Article 55(1)(b)):

Requirement: Assess and mitigate systemic risks, including sources, nature, likelihood, impact

Mitigation Measures:

- Implement appropriate safeguards
- Testing and filtering
- Alignment techniques
- Refusal capabilities (model refuses harmful requests)
- Deployment restrictions

Narahari

4. Track and Report Serious Incidents (Article 55(1)©):

Requirement: Track, document, and report relevant information about serious incidents and corrective measures to AI Office and national authorities

Serious Incident: As defined generally (death, serious harm, fundamental rights breach, systemic disruption)

Reporting: To European AI Office

---

5. Cybersecurity Protection (Article 55(1)(d)):

Requirement: Ensure appropriate level of cybersecurity for model and its infrastructure

Purpose: Prevent unauthorized access, model theft, misuse

Measures:

- Access controls
- Secure infrastructure
- Protection against attacks
- Monitoring

---

6. Report Energy Consumption (Article 55(1)(e)):

Requirement: Report through AI Office to European Commission on energy consumption for training

Purpose: Environmental transparency and sustainability

4.6 GPAI Providers and Downstream Providers

Relationship:

- **GPAI Provider**: Develops foundation model (e.g., OpenAI develops GPT-4)
- **Downstream Provider**: Integrates GPAI into specific application (e.g., company uses GPT-4 to build chatbot for customer service)

Responsibility Allocation:

- GPAI provider: Comply with GPAI obligations (Articles 53/55)
- Downstream provider: Comply with risk category obligations (e.g., if high-risk, comply with Articles 9-15)
- Downstream provider relies on GPAI provider's documentation to assess risks

Open-Source GPAI:

- Exemptions for open-source models (unless systemic risk)

Narahari

- Lighter obligations (encourage innovation and research)

---

5. AI LITERACY

Article 4: AI Literacy

Requirement: Providers and deployers must ensure sufficient level of AI literacy for their staff and persons dealing with AI

Definition (Article 3(56)): "AI literacy" means skills, knowledge and understanding that allows providers, deployers and affected persons to make informed decisions regarding AI systems

Content:

- Understanding AI capabilities and limitations
- Awareness of risks and benefits
- Knowledge of how to interact with AI
- Understanding of rights (for affected persons)
- Ability to interpret AI outputs

Implementation:

- Training programs for employees
- Education for users and affected persons
- Accessible information
- Ongoing learning

Purpose: Enable informed use and governance of AI; empower individuals

---

6. GOVERNANCE AND ENFORCEMENT

6.1 Governance Structure

European AI Office (within European Commission):

- Coordinates EU AI Act implementation
- Oversees GPAI models (especially systemic risk)
- Provides guidance and interpretation
- Facilitates cooperation among member states

European Artificial Intelligence Board:

- Advises and assists Commission and member states
- Ensures consistent application across EU
- Facilitates information exchange

Narahari

- Issues recommendations and opinions

National Competent Authorities (each member state):

- Designated national authority for AI Act enforcement
- Market surveillance and compliance monitoring
- Investigates complaints
- Imposes penalties

Notified Bodies:

- Conduct third-party conformity assessments
- Designated by member states, notified to Commission
- Must meet competence and independence criteria

6.2 Market Surveillance and Enforcement

Market Surveillance Authorities:

- Monitor AI systems on market
- Investigate suspected non-compliance
- Request information from providers/deployers
- Conduct inspections and audits
- Order corrective measures
- Prohibit or withdraw non-compliant AI from market

Enforcement Powers:

- Access to data, documentation, source code
- Test AI systems
- Require demonstrations
- Order risk assessments
- Impose penalties

6.3 Penalties and Fines

Maximum Administrative Fines (Article 99):

For Prohibited AI Practices (Article 5):

- **Up to €35 million OR 7% of total worldwide annual turnover** (whichever is higher)
- Most severe penalty

Narahari

For Non-Compliance with High-Risk AI Obligations (Articles 9-15):

- **Up to €15 million OR 3% of total worldwide annual turnover** (whichever is higher)

For Inaccurate, Incomplete, or Misleading Information to Authorities:

- **Up to €7.5 million OR 1.5% of total worldwide annual turnover** (whichever is higher)

For Other Violations (e.g., transparency obligations, GPAI obligations):

- **Up to €15 million OR 3% of total worldwide annual turnover** (whichever is higher)

SME Adjustments: For SMEs and startups, fines capped at percentages of turnover (lower caps) or specific monetary amounts (whichever is lower)

Factors Considered:

- Nature, gravity, duration of violation
- Intentional vs. negligent
- Actions taken to mitigate harm
- Degree of responsibility
- Previous violations
- Cooperation with authorities
- Affected parties
- Financial situation (ability to pay)

Other Sanctions:

- Orders to stop non-compliant AI
- Product recall or withdrawal from market
- Temporary restriction or prohibition
- Public warnings

---

7. IMPLEMENTATION TIMELINE

EU AI Act Entered into Force: August 1, 2024

Phased Application (staggered deadlines):

February 2, 2025 (6 months):

- **Prohibited AI practices (Article 5)** fully apply
- Organizations must cease prohibited uses

Narahari

August 2, 2025 (12 months):

- **GPAI obligations (Articles 53, 55)** apply
- Providers of foundation models must comply
- Codes of practice developed

August 2, 2026 (24 months):

- **High-risk AI obligations (Chapter III, Section 2)** apply for most systems
- Providers and deployers must comply with full requirements
- Conformity assessments required before market placement

August 2, 2027 (36 months):

- **High-risk AI that are components of large-scale IT systems** (e.g., Schengen, Eurodac) must comply
- Allows extra time for integration into existing EU systems

Transitional Provisions:

- AI systems already on market before August 2, 2026 (and compliant with prior laws) have grace period
- Must comply by August 2, 2030 (or earlier if substantial modification)

---

8. OTHER KEY PROVISIONS

8.1 Regulatory Sandboxes (Article 57)

Purpose: Provide controlled environment for developing, testing, and validating innovative AI under regulatory supervision

Benefits:

- Reduce time and cost for innovation
- Guidance from authorities
- Test in realistic conditions with safeguards
- Learn and improve AI governance

Access: Priority for SMEs, startups

National Authorities: Member states establish sandboxes

Narahari

8.2 Codes of Conduct (Article 95)

Voluntary: Encourages providers to adopt codes of conduct for non-high-risk AI

Content: Voluntary commitments to responsible AI principles (fairness, transparency, human oversight, etc.)

Purpose: Encourage best practices beyond legal requirements

8.3 Standards and Harmonization

Harmonized Standards: European standardization organizations (CEN, CENELEC, ETSI) develop standards

Presumption of Conformity: Compliance with harmonized standards presumes compliance with EU AI Act requirements

Importance: Provides clear technical guidance for compliance

8.4 Confidentiality and Trade Secrets (Article 78)

Protection: Authorities must respect confidential information and trade secrets

Access to Source Code: Authorities may request access for conformity assessment, but only when necessary and with safeguards

Balance: Enforcement needs vs. protecting proprietary information

---

9. KEY DEFINITIONS FOR MODULE 6

AI System: Machine-based system designed to operate with varying levels of autonomy, inferring from inputs how to generate outputs that can influence environments.

Provider: Entity developing AI or having it developed, placing it on EU market under own name.

Deployer: Entity using AI system under their authority (except personal non-professional use).

Importer: Entity in EU placing on market AI bearing non-EU provider's name.

Distributor: Entity in supply chain making AI available on market (not provider or importer).

Prohibited AI: Unacceptable risk AI practices banned under Article 5 (social scoring, manipulation, untargeted scraping, etc.).

High-Risk AI: AI posing significant risks to health, safety, fundamental rights; subject to strict requirements (Articles 9-15).

Limited Risk AI: AI with transparency risks; disclosure obligations (Article 50).

Minimal Risk AI: AI with no specific EU AI Act obligations.

General-Purpose AI (GPAI): AI model with significant generality, capable of wide range of tasks (foundation models).

Narahari

GPAI with Systemic Risk: GPAI with high-impact capabilities posing systemic risks (e.g., trained with >10^25 FLOPs).

Conformity Assessment: Process demonstrating AI complies with EU AI Act requirements.

CE Marking: Mark indicating high-risk AI complies with EU AI Act and other regulations.

EU Database: Public database where high-risk AI systems must be registered.

Risk Management System: Systematic process for identifying, analyzing, estimating, mitigating AI risks throughout lifecycle (Article 9).

Quality Management System (QMS): System ensuring compliance with EU AI Act (Article 17).

Fundamental Rights Impact Assessment (FRIA): Assessment by deployers of high-risk AI impacts on fundamental rights (Article 27).

Technical Documentation: Documentation demonstrating compliance (Article 11); retained 10 years.

Logging: Automatic recording of events during AI operation (Article 12).

Human Oversight: Measures enabling human intervention, interpretation, and stopping AI (Article 14).

Serious Incident: Incident causing death, serious harm, or fundamental rights breach; must be reported (Article 73).

Notified Body: Third-party organization conducting conformity assessments for certain high-risk AI.

AI Literacy: Skills, knowledge, understanding enabling informed decisions about AI (Article 4).

European AI Office: EU body coordinating AI Act implementation, overseeing GPAI.

Market Surveillance Authority: National authority enforcing AI Act, monitoring compliance.

---

10. STUDY TIPS FOR MODULE 6

Key Concepts to Master:

1. ✅ Understand **four risk categories** (Prohibited, High-Risk, Limited Risk, Minimal) with examples
2. ✅ Know **seven prohibited AI practices** (Article 5) and why each is banned
3. ✅ Memorize **eight high-risk AI categories** (Annex III)
4. ✅ Master **high-risk AI provider obligations** (Articles 9-15)
5. ✅ Understand **deployer obligations** including FRIA (Articles 26-27)
6. ✅ Know **four key roles** (Provider, Deployer, Importer, Distributor) and responsibilities
7. ✅ Understand **GPAI** two tiers and obligations (Articles 53, 55)

Narahari

8. ✅ Know **transparency requirements** (Article 50) for limited-risk AI
9. ✅ Master **penalty structure** (€35M/7%, €15M/3%, €7.5M/1.5%)
10. ✅ Understand **implementation timeline** (key dates: Feb 2025, Aug 2025, Aug 2026, Aug 2027)

Common Pitfalls to Avoid:

- ❌ Confusing provider vs. deployer obligations
- ❌ Not knowing which high-risk categories require third-party conformity assessment (biometrics)
- ❌ Mixing up prohibited practices (Article 5) vs. high-risk requirements
- ❌ Forgetting FRIA required only for certain deployers (public authorities, services of general interest)
- ❌ Not understanding GPAI systemic risk threshold (10^25 FLOPs)
- ❌ Confusing timeline dates and what applies when

Practical Application:

- For each prohibited practice, understand the rationale
- Map high-risk categories to real-world AI systems
- Trace provider obligations (Articles 9-15) through development lifecycle
- Design FRIA process for a high-risk AI deployment
- Compare standard GPAI vs. systemic risk GPAI obligations
- Calculate penalties for different violation scenarios

Memorization Aids:

Four Risk Categories (P-H-L-M):

- **P**rohibited (unacceptable risk, Article 5, banned)
- **H**igh-Risk (Annex III, strict requirements)
- **L**imited Risk (transparency obligations, Article 50)
- **M**inimal Risk (no specific obligations)

Seven Prohibited Practices (Article 5):

1. **M**anipulation/exploitation
2. **S**ocial scoring
3. **P**redictive policing (profiling-based)
4. **F**acial recognition database (untargeted scraping)

Narahari

5. **E**motion recognition (workplace/education)
6. **B**iometric categorization (sensitive attributes)
7. **R**eal-time RBI (law enforcement, with exceptions)

Mnemonic: **M-S-P-F-E-B-R**

Eight High-Risk Categories (Annex III - B-C-E-E-A-L-M-J):

1. **B**iometrics
2. **C**ritical infrastructure
3. **E**ducation
4. **E**mployment
5. **A**ccess to essential services (credit, insurance, welfare)
6. **L**aw enforcement
7. **M**igration, asylum, border control
8. **J**ustice and democratic processes

Provider Obligations (Articles 9-15 - R-D-T-L-T-H-A):

- Article 9: **R**isk management
- Article 10: **D**ata governance
- Article 11: **T**echnical documentation
- Article 12: **L**ogging (record-keeping)
- Article 13: **T**ransparency to deployers
- Article 14: **H**uman oversight
- Article 15: **A**ccuracy, robustness, cybersecurity

GPAI Standard Obligations (Article 53 - T-I-C-S):

1. **T**echnical documentation
2. **I**nformation to downstream providers
3. **C**opyright compliance policy
4. **S**ummary of training data (public)

GPAI Systemic Risk Additional (Article 55 - E-R-A-T-C-E):

1. Model **E**valuation
2. **R**ed teaming (adversarial testing)
3. **A**ssess and mitigate systemic risks
4. **T**rack and report serious incidents

Narahari

5. **C**ybersecurity
6. **E**nergy consumption reporting

Penalty Tiers:

- **Prohibited**: €35M or 7% (highest)
- **High-Risk non-compliance**: €15M or 3%
- **Misleading info**: €7.5M or 1.5%
- **Other violations**: €15M or 3%

Implementation Timeline:

- **Feb 2025** (6 mo): Prohibited AI banned
- **Aug 2025** (12 mo): GPAI obligations
- **Aug 2026** (24 mo): High-risk obligations
- **Aug 2027** (36 mo): Large-scale IT systems

Narahari